

VAPT Internship
WEEK 11 ASSIGNMENT REPORT
Buffer Overflow, Wireless Security & Social Engineering

Submitted by

Sulav Adhikari

VAPT Internship Program

June 2026

TABLE OF CONTENTS

TABLE OF CONTENTS.....	i
TABLE OF FIGURES.....	iii
EXECUTIVE SUMMARY	1
1. WPA2 WIRELESS SECURITY RESEARCH.....	2
1.1 Introduction to Wireless Security	2
1.2 What is WPA2?.....	2
1.3 WPA2 Authentication Process.....	3
1.4 WPA2 Four-Way Handshake	4
1.5 PMK, PTK, and GTK	5
1.6 Deauthentication Attack.....	6
1.7 Evil Twin Attack.....	7
1.8 Rogue Access Point Attack.....	8
1.9 WPA2 vs WPA3	9
1.10 Wireless Security Best Practices.....	9
2. PHISHING EMAIL ANALYSIS	11
2.1 Scenario Overview.....	11
2.2 Phishing Indicators.....	11
2.3 Social Engineering Techniques Used	12
2.4 Risks if the Employee Clicks the Link	12
2.5 Recommended Employee Actions.....	12
2.6 Organizational Controls Against Phishing.....	12
3. BUFFER OVERFLOW CASE STUDY – CVE-2021-3156 (BARON SAMEDIT).....	14
3.1 Vulnerability Overview	14
3.2 Background of Sudo	14
3.3 Root Cause of the Vulnerability	14
3.4 How the Buffer Overflow Occurred	15
3.5 Attack Methodology	15
3.6 Impact on Organizations	16
3.7 Detection Methods	16
3.8 Mitigation Techniques	17
3.9 Lessons Learned.....	17
4. CONCLUSION.....	19

5. REFERENCES	20
---------------------	----

TABLE OF FIGURES

Figure 1: WPA2 Authentication Flow	3
Figure 2: WPA2 Four-Way Handshake Process.....	5
Figure 3: Deauthentication Attack Flow	7
Figure 4: Evil Twin Attack Flow	8
Figure 5: Buffer Overflow – Normal vs Vulnerable Process	15

EXECUTIVE SUMMARY

Modern organizations rely heavily on wireless networks, internet-based communication, and software systems to conduct daily operations. While these technologies improve productivity and connectivity, they also introduce various cybersecurity risks. Cybercriminals continuously exploit vulnerabilities in wireless networks, human behavior, and software applications to gain unauthorized access to sensitive information and systems.

This report examines three major cybersecurity topics: WPA2 wireless security, phishing and social engineering attacks, and buffer overflow vulnerabilities. The first section focuses on WPA2 wireless security, discussing its authentication process, encryption mechanisms, wireless attacks, and security best practices. The second section analyzes a phishing email scenario and explains how attackers manipulate users through social engineering techniques. The final section presents a detailed case study of CVE-2021-3156 (Baron Samedit), a critical buffer overflow vulnerability discovered in the Linux sudo utility.

Understanding these threats is essential for organizations seeking to protect their information assets. Effective cybersecurity requires a combination of technical controls, security awareness training, vulnerability management, and continuous monitoring.

1. WPA2 WIRELESS SECURITY RESEARCH

1.1 Introduction to Wireless Security

Wireless networks have become an essential component of modern communication. Unlike wired networks, wireless networks transmit data through radio signals, making them more vulnerable to interception and unauthorized access. To protect wireless communications, various security standards have been developed over time.

Early wireless security relied on Wired Equivalent Privacy (WEP), which was later replaced by Wi-Fi Protected Access (WPA). WPA2 was introduced to provide stronger encryption and improved authentication mechanisms. It became the industry standard for securing wireless networks and remains widely used today.

1.2 What is WPA2?

Wi-Fi Protected Access 2 (WPA2) is a wireless security protocol developed by the Wi-Fi Alliance in 2004. It was designed to provide stronger security than previous wireless security standards. WPA2 uses the Advanced Encryption Standard (AES) algorithm, which is considered highly secure and is widely adopted by governments and organizations worldwide. The protocol ensures confidentiality, integrity, and authentication for wireless communications.

WPA2 operates in two modes:

WPA2-Personal

WPA2-Personal uses a Pre-Shared Key (PSK), commonly referred to as a Wi-Fi password. This mode is suitable for home and small office environments.

WPA2-Enterprise

WPA2-Enterprise uses an authentication server such as RADIUS to verify user credentials individually. It is commonly used in educational institutions, government offices, and large enterprises.

Advantages of WPA2

- Strong AES encryption
- Better protection against unauthorized access
- Improved authentication mechanisms
- Widely supported by networking devices

- Enhanced data confidentiality

1.3 WPA2 Authentication Process

The WPA2 authentication process ensures that only authorized users can connect to the wireless network. The process involves several sequential steps that verify the identity of the connecting device and establish secure communication.

Authentication Steps

1. The client device scans for available wireless networks.
2. The user selects the desired network.
3. The client sends a connection request to the Access Point (AP).
4. Authentication credentials are verified.
5. A Pairwise Master Key (PMK) is generated.
6. The 4-Way Handshake process begins.
7. Session encryption keys are established.
8. Secure communication starts.

The authentication process prevents unauthorized users from accessing protected wireless networks and ensures secure communication between devices.

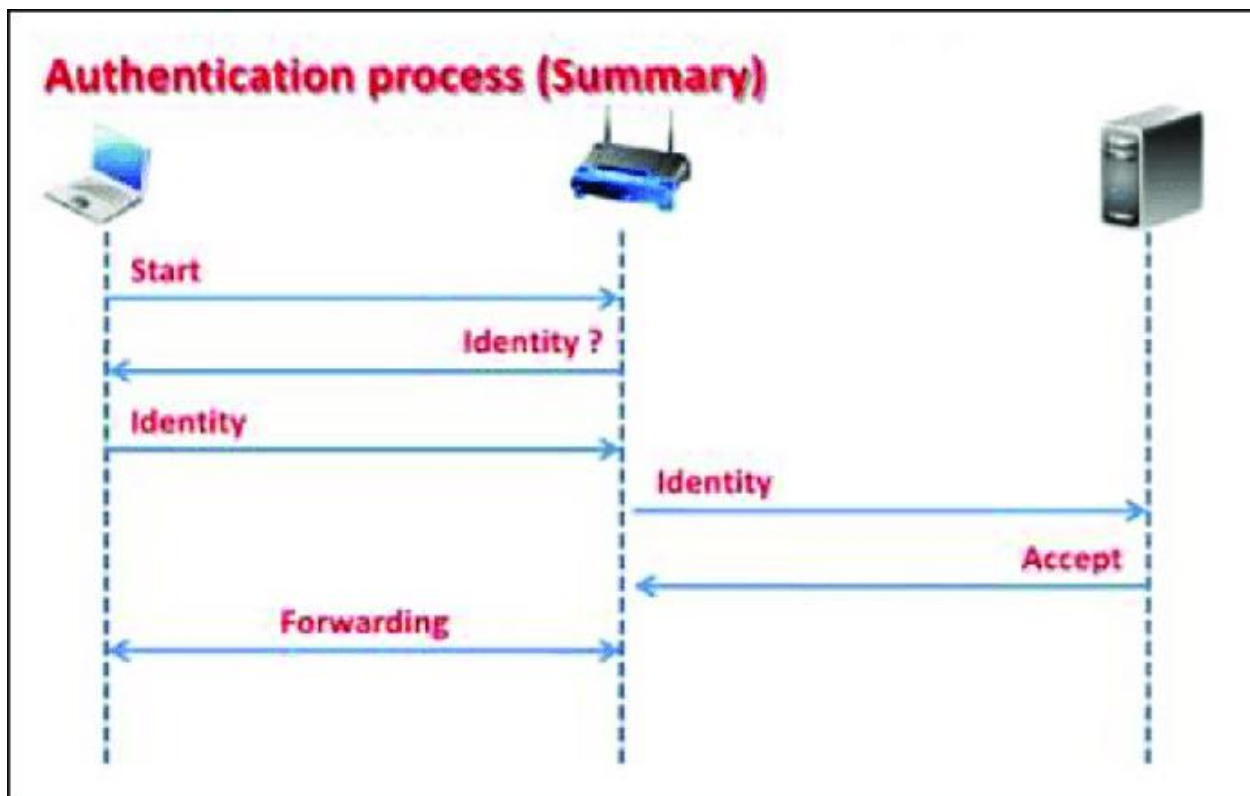


Figure 1: WPA2 Authentication Flow

1.4 WPA2 Four-Way Handshake

The WPA2 Four-Way Handshake is a key management process used to generate encryption keys securely after authentication. The primary objective of the handshake is to establish session keys without transmitting the actual password across the network.

Message 1

The Access Point sends a random value called ANonce to the client.

Message 2

The client generates another random value called SNonce. Using ANonce, SNonce, and the PMK, it creates the Pairwise Transient Key (PTK) and sends a response to the Access Point.

Message 3

The Access Point verifies the response and sends the Group Temporal Key (GTK) to the client.

Message 4

The client confirms successful installation of the keys.

The handshake allows secure generation and exchange of encryption keys while preventing exposure of the wireless password.

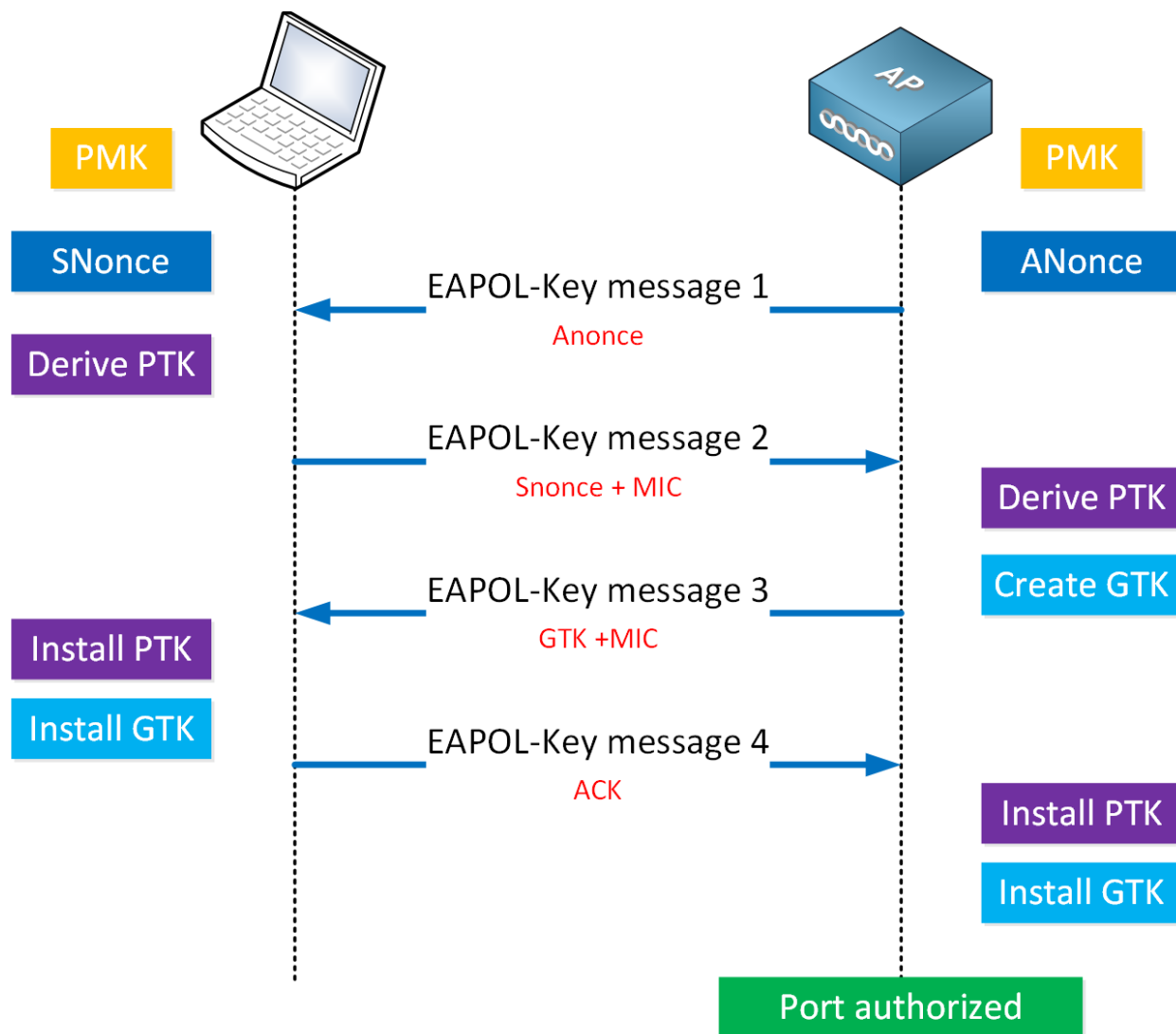


Figure 2: WPA2 Four-Way Handshake Process

1.5 PMK, PTK, and GTK

WPA2 relies on multiple cryptographic keys to secure communications. Each key serves a distinct purpose in the overall security architecture.

Pairwise Master Key (PMK)

The PMK is derived from the wireless password or generated through enterprise authentication methods. It serves as the master secret used during key generation.

Pairwise Transient Key (PTK)

The PTK is generated during the Four-Way Handshake and is used to encrypt communication between a specific client and access point.

Group Temporal Key (GTK)

The GTK is used to encrypt multicast and broadcast traffic sent to all devices connected to the wireless network.

Key	Full Form	Purpose
PMK	Pairwise Master Key	Master authentication key
PTK	Pairwise Transient Key	Encrypts client-to-AP communication
GTK	Group Temporal Key	Encrypts multicast and broadcast traffic

These keys work together to ensure secure wireless communication and protect data from interception.

1.6 Deauthentication Attack

A deauthentication attack is a wireless attack that forces devices to disconnect from a wireless network. Attackers send forged deauthentication frames that appear to originate from a legitimate access point.

Attack Process

9. Attacker identifies target network.
10. Deauthentication packets are transmitted.
11. Connected users are disconnected.
12. Users attempt to reconnect.
13. Additional attacks such as credential capture may be launched.

Risks

- Network disruption and Denial of Service (DoS)
- Credential capture opportunities during reconnection
- User inconvenience and productivity loss

Prevention

- Enable Protected Management Frames (PMF)
- Monitor wireless traffic for deauthentication floods
- Deploy Wireless Intrusion Detection Systems

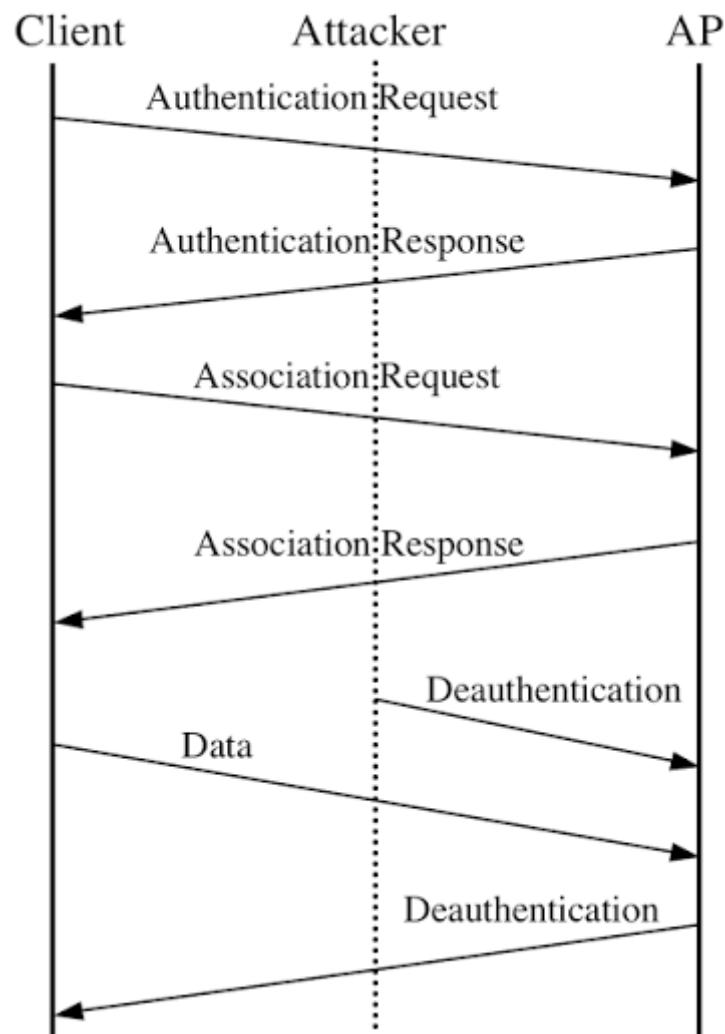


Figure 3: Deauthentication Attack Flow

1.7 Evil Twin Attack

An Evil Twin attack occurs when an attacker creates a fake wireless network that mimics a legitimate network. Users unknowingly connect to the fake network, allowing attackers to monitor communications and steal credentials.

Attack Flow

14. Attacker identifies a target legitimate wireless network.
15. A fake access point with the same SSID is created.
16. The victim connects to the fake access point.
17. Attacker intercepts all network traffic.
18. Credentials and sensitive data are captured.

Risks

- Password theft and identity theft
- Financial fraud through intercepted transactions
- Data interception and man-in-the-middle attacks

Prevention

- Verify network names and certificates carefully
- Avoid connecting to unknown Wi-Fi networks
- Use VPN services on public networks
- Implement certificate-based authentication

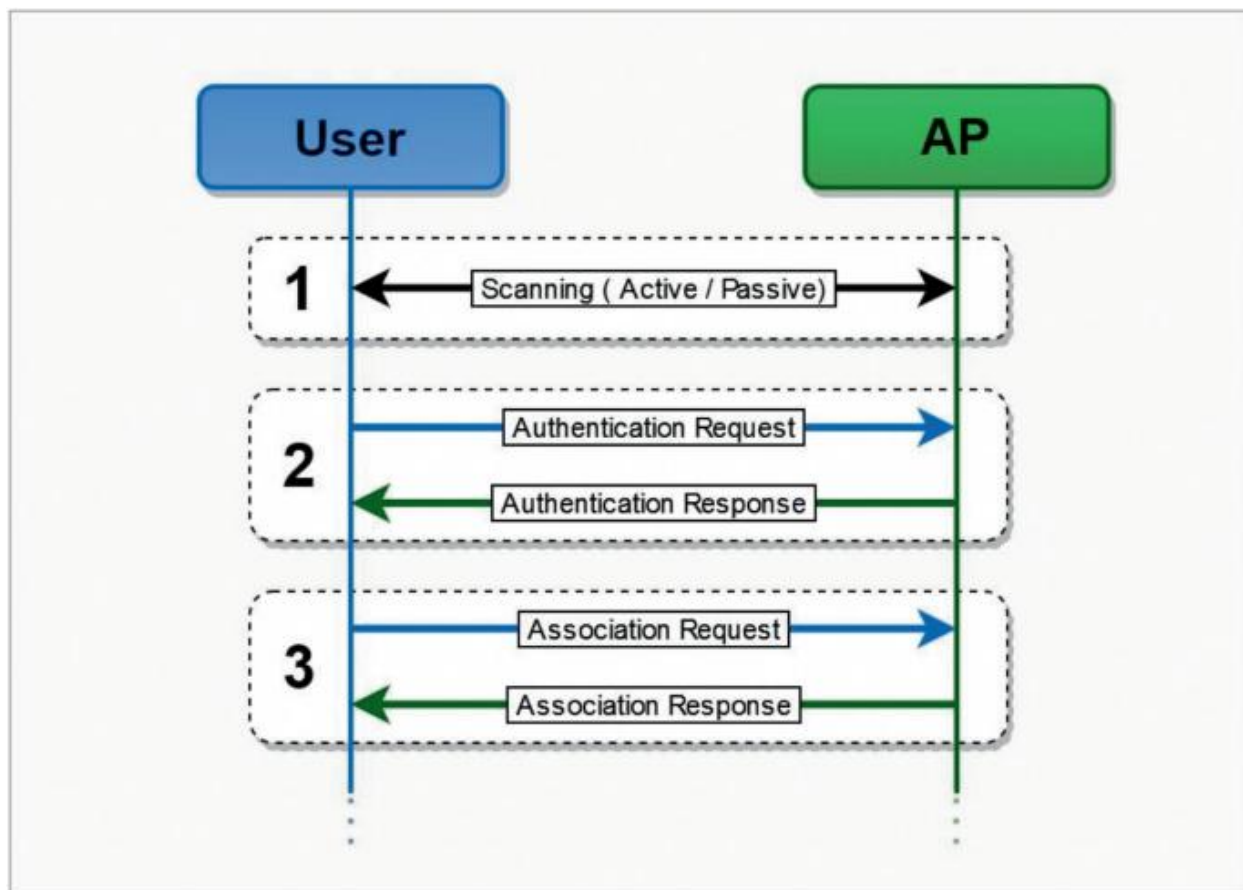


Figure 4: Evil Twin Attack Flow

1.8 Rogue Access Point Attack

A Rogue Access Point is an unauthorized wireless device installed within an organization's network without the knowledge or permission of network administrators. Attackers may deploy rogue access points to bypass security controls and gain internal network access.

Risks

- Unauthorized network access and data leakage
- Malware distribution within the network
- Security policy violations
- Bypassing of perimeter security controls

Prevention

- Conduct regular wireless audits
- Monitor for unauthorized devices continuously
- Implement Network Access Control (NAC)
- Use Wireless Intrusion Detection Systems

1.9 WPA2 vs WPA3

WPA3 was introduced in 2018 to address known weaknesses in WPA2. The following table summarizes the key differences between the two standards.

Feature	WPA2	WPA3
Release Year	2004	2018
Encryption	AES (CCMP)	AES Enhanced (GCMP-256)
Authentication	PSK (Pre-Shared Key)	SAE (Simultaneous Auth of Equals)
Password Protection	Moderate	Strong
Brute Force Resistance	Limited	Improved
Forward Secrecy	Not supported	Supported
Security Level	High	Very High

WPA3 improves security by introducing Simultaneous Authentication of Equals (SAE), which provides stronger protection against password guessing attacks and enables forward secrecy for encrypted communications.

1.10 Wireless Security Best Practices

Organizations should implement the following wireless security measures to reduce the risk of wireless attacks:

- Use strong and unique passwords of at least 12 characters.

- Enable WPA3 when available on supported devices.
- Regularly update router and access point firmware.
- Disable unused wireless services and features.
- Separate guest networks from internal corporate networks.
- Monitor wireless traffic continuously for anomalies.
- Enable Multi-Factor Authentication for network access.
- Restrict administrative access to network devices.
- Conduct periodic wireless security assessments.
- Train users on wireless security threats and safe practices.

2. PHISHING EMAIL ANALYSIS

2.1 Scenario Overview

An employee receives an email allegedly from "IT Support" stating that their account will be disabled within 24 hours unless they immediately reset their password using a provided hyperlink. This scenario represents a common phishing attack designed to steal user credentials through social engineering.

2.2 Phishing Indicators

Several indicators suggest that the email is malicious:

1. Urgent Language

The email creates pressure by stating that action must be taken within 24 hours. This urgency is designed to prevent the recipient from thinking critically about the request.

2. Threat of Account Suspension

Attackers attempt to create fear by threatening account deactivation. Fear-based messaging is a hallmark of phishing campaigns.

3. Suspicious Hyperlink

The email contains a link directing users to an unknown or spoofed website. The link may appear legitimate at first glance but redirect to a malicious page.

4. Request for Credentials

Legitimate organizations rarely request passwords through email links. Any such request is a strong indicator of phishing.

5. Generic Greeting

Many phishing emails use generic greetings such as "Dear User" rather than addressing the recipient by name.

6. Sender Address Mismatch

The sender's email address may not match the organization's official domain. Attackers often use lookalike domains.

7. Grammar and Formatting Errors

Many phishing emails contain unusual wording, grammatical mistakes, or inconsistent formatting that differ from official communications.

2.3 Social Engineering Techniques Used

Technique	Description
Authority	The attacker impersonates an official IT support representative to gain trust.
Urgency	The victim is pressured to act quickly within a defined time limit.
Fear	Threat of losing account access encourages immediate and uncritical action.
Trust Exploitation	The attacker relies on the victim's trust in organizational communications.
Deception	The email disguises itself as a legitimate account notification.

2.4 Risks if the Employee Clicks the Link

Clicking the malicious link may result in several serious consequences:

- **Credential Theft:** The attacker may obtain the employee's username and password.
- **Malware Installation:** Malicious software may be downloaded automatically in a drive-by attack.
- **Financial Loss:** Compromised accounts may be used for fraudulent transactions.
- **Data Breach:** Sensitive organizational information may be exposed or stolen.
- **Identity Theft:** Personal information may be misused for fraudulent activities.
- **Lateral Movement:** Attackers may use compromised credentials to access additional systems.

2.5 Recommended Employee Actions

19. Avoid clicking any links or downloading attachments from the suspicious email.
20. Verify the email directly with the IT department through official channels.
21. Report the message to security personnel or the incident response team.
22. Delete the email after reporting it.
23. Change credentials immediately if any interaction with the link occurred.
24. Monitor accounts for suspicious activity and unauthorized access.

2.6 Organizational Controls Against Phishing

Security Control	Purpose
Email Filtering	Blocks malicious emails before they reach employees.
Multi-Factor Authentication (MFA)	Protects accounts even if passwords are stolen.
Security Awareness Training	Educates employees on recognizing phishing attempts.
URL Filtering	Blocks access to known malicious websites.
Endpoint Protection	Detects and removes malware from devices.
Email Authentication (SPF, DKIM, DMARC)	Prevents email spoofing and domain impersonation.
Security Monitoring (SIEM)	Detects and responds to suspicious account activity.

Phishing attacks continue to be one of the most successful attack methods because they exploit human psychology rather than technical vulnerabilities. Organizations must combine technical controls with employee awareness programs to reduce the risk of successful phishing attacks.

3. BUFFER OVERFLOW CASE STUDY – CVE-2021-3156 (BARON SAMEDIT)

3.1 Vulnerability Overview

CVE-2021-3156, commonly known as Baron Samedit, is a critical privilege escalation vulnerability discovered in the sudo utility on Linux and Unix-based operating systems. The vulnerability was publicly disclosed in January 2021 by Qualys researchers and received a CVSS score of 7.8 due to its severity. Successful exploitation allowed local users without special privileges to gain complete root-level access on the affected system.

Attribute	Detail
CVE Identifier	CVE-2021-3156
Common Name	Baron Samedit
CVSS Score	7.8 (High)
Affected Software	sudo (versions prior to 1.9.5p2)
Vulnerability Type	Heap-based Buffer Overflow
Disclosure Date	January 26, 2021
Impact	Local Privilege Escalation to Root

3.2 Background of Sudo

Sudo is a widely used utility that allows authorized users to execute commands with elevated privileges. System administrators rely on sudo to manage systems securely while maintaining accountability through logging and permission controls. Because sudo is installed on millions of Linux and Unix systems worldwide, vulnerabilities affecting it can have widespread and significant consequences.

3.3 Root Cause of the Vulnerability

The vulnerability resulted from improper input validation and unsafe memory handling within the sudo source code. When processing specific command-line arguments that included a backslash character followed by special sequences, sudo failed to correctly validate the length of user input.

This caused data to be written beyond the boundaries of allocated heap memory, resulting in a heap-based buffer overflow. The improper handling of the `-i` and `-s` command-line flags was directly responsible for triggering this condition. An attacker with access to any local user account could exploit this flaw without requiring any special system permissions.

3.4 How the Buffer Overflow Occurred

The following diagram illustrates the difference between normal sudo execution and the vulnerable process triggered by CVE-2021-3156.

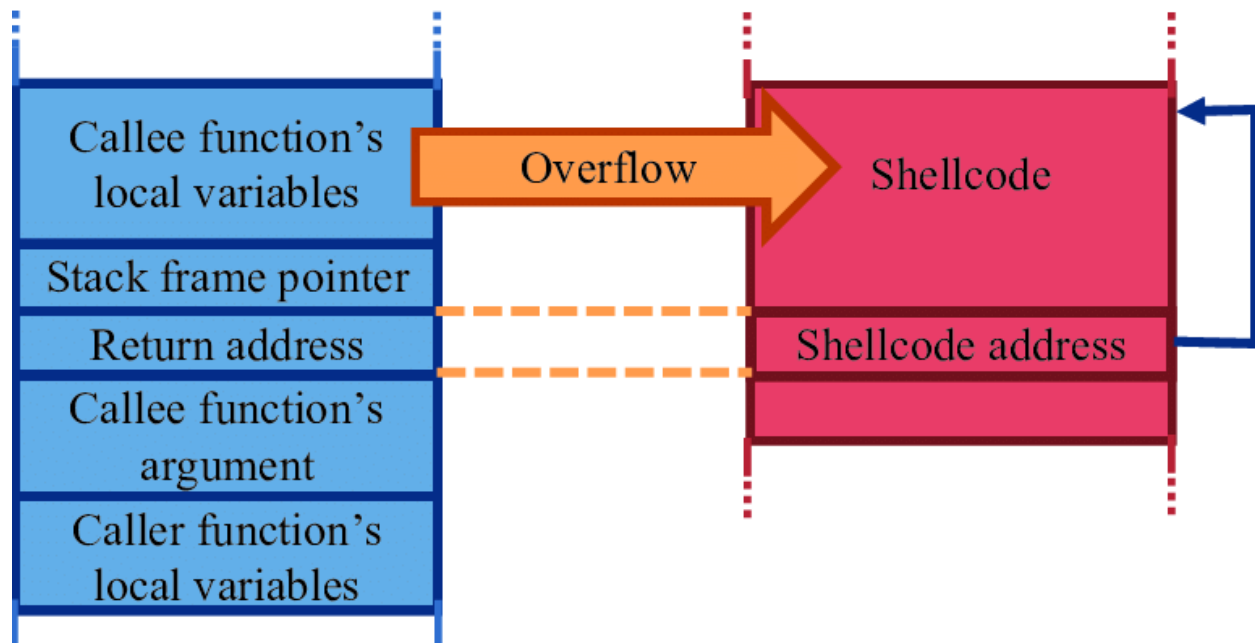


Figure 5: Buffer Overflow

In the normal process, user input is validated correctly and commands execute within safe memory boundaries. In the vulnerable process, improperly validated input causes a heap buffer overflow that corrupts adjacent memory structures, enabling the attacker to manipulate program execution flow and escalate privileges to root.

3.5 Attack Methodology

Step 1: Obtain Local Access

The attacker gains access to a Linux system through any local user account, including low-privileged accounts.

Step 2: Craft Malicious Input

Specially designed command-line arguments containing backslash sequences are prepared to trigger the overflow condition.

Step 3: Trigger Overflow

The malicious input is passed to sudo using the `sudoedit -s` or `sudo -i` flags, causing the heap buffer overflow.

Step 4: Corrupt Memory

Heap memory structures are overwritten, allowing the attacker to control the program's execution path.

Step 5: Escalate Privileges

The attacker gains root privileges and full control of the compromised system.

3.6 Impact on Organizations

Impact Category	Description
Unauthorized Access	Attackers gain full administrative (root) privileges on affected systems.
Data Exposure	Sensitive files and credentials accessible only to root can be stolen.
System Compromise	Entire systems can be controlled, modified, or destroyed by attackers.
Operational Disruption	Critical services can be interrupted or taken offline.
Compliance Violations	Compromised systems may violate regulatory and contractual obligations.
Persistence	Attackers can install backdoors to maintain long-term access.

The widespread deployment of sudo across Linux and Unix environments meant that the vulnerability potentially affected millions of systems globally, including servers in critical infrastructure, cloud environments, and enterprise data centers.

3.7 Detection Methods

Organizations can detect exploitation attempts through the following methods:

- Log Analysis: Monitor /var/log/auth.log and /var/log/sudo.log for unusual sudo invocations.
- SIEM Integration: Analyze privilege escalation events and alerts from centralized logging.
- Vulnerability Scanning: Identify systems running sudo versions prior to 1.9.5p2.
- Intrusion Detection Systems: Deploy host-based IDS rules to detect exploitation patterns.
- File Integrity Monitoring: Identify unauthorized changes to system files after exploitation.

- Behavioral Analysis: Monitor for unexpected root process creation from low-privileged accounts.

3.8 Mitigation Techniques

Apply Security Updates

Install the patched sudo version (1.9.5p2 or later) immediately. Most Linux distributions released patches shortly after the vulnerability was disclosed.

Principle of Least Privilege

Limit sudo permissions to only the commands necessary for each user's role. Avoid granting unrestricted sudo access.

Continuous Monitoring

Monitor privileged activities and audit sudo usage regularly.

Vulnerability Management

Conduct regular vulnerability assessments and penetration tests to identify unpatched systems.

System Hardening

Remove unnecessary services and software. Apply operating system hardening benchmarks such as CIS Benchmarks.

Security Awareness

Train administrators on emerging threats and the importance of timely patching.

3.9 Lessons Learned

The Baron Samedit vulnerability highlights several important cybersecurity lessons:

- Secure coding practices and rigorous input validation are essential during software development.
- Vulnerabilities in widely deployed, trusted utilities can remain undiscovered for years.
- Security patches must be applied promptly to reduce the window of exposure.
- Vulnerability management programs are critical for identifying and remediating known weaknesses.
- Privileged applications require additional code review and security testing.

- Continuous monitoring and anomaly detection improve the ability to identify exploitation attempts.

4. CONCLUSION

Cybersecurity threats continue to evolve and affect organizations of all sizes. This report has examined three major areas of concern: wireless network security, social engineering and phishing, and software vulnerabilities through buffer overflows.

WPA2 provides strong wireless security through authentication, encryption, and key management mechanisms. However, wireless attacks such as deauthentication attacks, Evil Twin attacks, and rogue access points remain significant threats. Organizations should transition to WPA3 where possible and implement continuous wireless monitoring.

Phishing attacks demonstrate how attackers effectively exploit human behavior through urgency, authority, and fear. Organizations must educate users and deploy layered technical controls to reduce the success rate of phishing campaigns.

The Baron Samedit vulnerability illustrates how software flaws in trusted utilities can lead to serious security incidents with widespread impact. A comprehensive security strategy should include secure wireless configurations, employee awareness training, vulnerability management, regular patching, and continuous monitoring.

5. REFERENCES

1. National Institute of Standards and Technology (NIST). Wireless Network Security Guidelines. NIST Special Publication 800-153.
2. Wi-Fi Alliance. WPA2 and WPA3 Security Technical Specifications. Wi-Fi Alliance Documentation, 2018.
3. OWASP Foundation. Phishing and Social Engineering Prevention Guidelines. OWASP, 2023.
4. Qualys Security Research. CVE-2021-3156: Heap-Based Buffer Overflow in Sudo (Baron Samedit). Qualys Security Advisory, January 2021.
5. Linux sudo Project. Security Advisories and Release Notes. sudo version 1.9.5p2. Available at: <https://www.sudo.ws/>
6. Cybersecurity and Infrastructure Security Agency (CISA). Alert on Privilege Escalation Vulnerabilities. CISA Security Publications, 2021.
7. IEEE. Research Publications on Wireless Network Security. IEEE Xplore Digital Library.
8. Stallings, W. & Brown, L. Computer Security: Principles and Practice, 4th Edition. Pearson, 2018.
9. Stallings, W. Network Security Essentials: Applications and Standards, 6th Edition. Pearson, 2017.
10. Linux Security Mailing List. Official Security Announcements for CVE-2021-3156. Available at: <https://oss-security.openwall.org/>